

High-level logic vulnerability

Topic: Business Logic Vulnerabilities | Difficulty: Apprentice

Description

The shopping cart fails to validate that product quantities must be positive integers. An attacker can add a second item to the cart with a negative quantity which subtracts from the cart total. This allows purchase of expensive items at a near-zero price by offsetting costs with negatively-quantified cheaper items.

Steps to Exploit

1. Add the target expensive item (jacket) to the cart normally.
2. Add a second less expensive item to the cart.
3. Intercept the second add-to-cart POST request in Burp Suite.
4. Change the 'quantity' parameter to a large negative value (e.g., -100).
5. Forward the request and observe the cart total has decreased significantly.
6. Adjust the negative quantity until the total matches available store credit.
7. Complete the checkout.

Proof of Concept

Normal add:

```
POST /cart
productId=2&quantity=1
```

Negative quantity:

```
POST /cart
productId=2&quantity=-100
```

Cart effect:

Total reduced by 100x the second item price; overall total near zero.

Impact

- Purchase of expensive items at near-zero cost via arithmetic manipulation.
- Financial loss through negative quantity exploitation.
- Demonstrates failure to implement basic input range validation.

Mitigation / Remediation

1. Validate that all quantity values are positive integers greater than zero.
2. Enforce server-side minimum and maximum quantity bounds.
3. Validate the cart total server-side before processing payment.
4. Implement business rule checks that reject nonsensical or negative cart states.

CVSS Score

CVSS v3.1: 6.5 (Medium)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

CVSS Justification

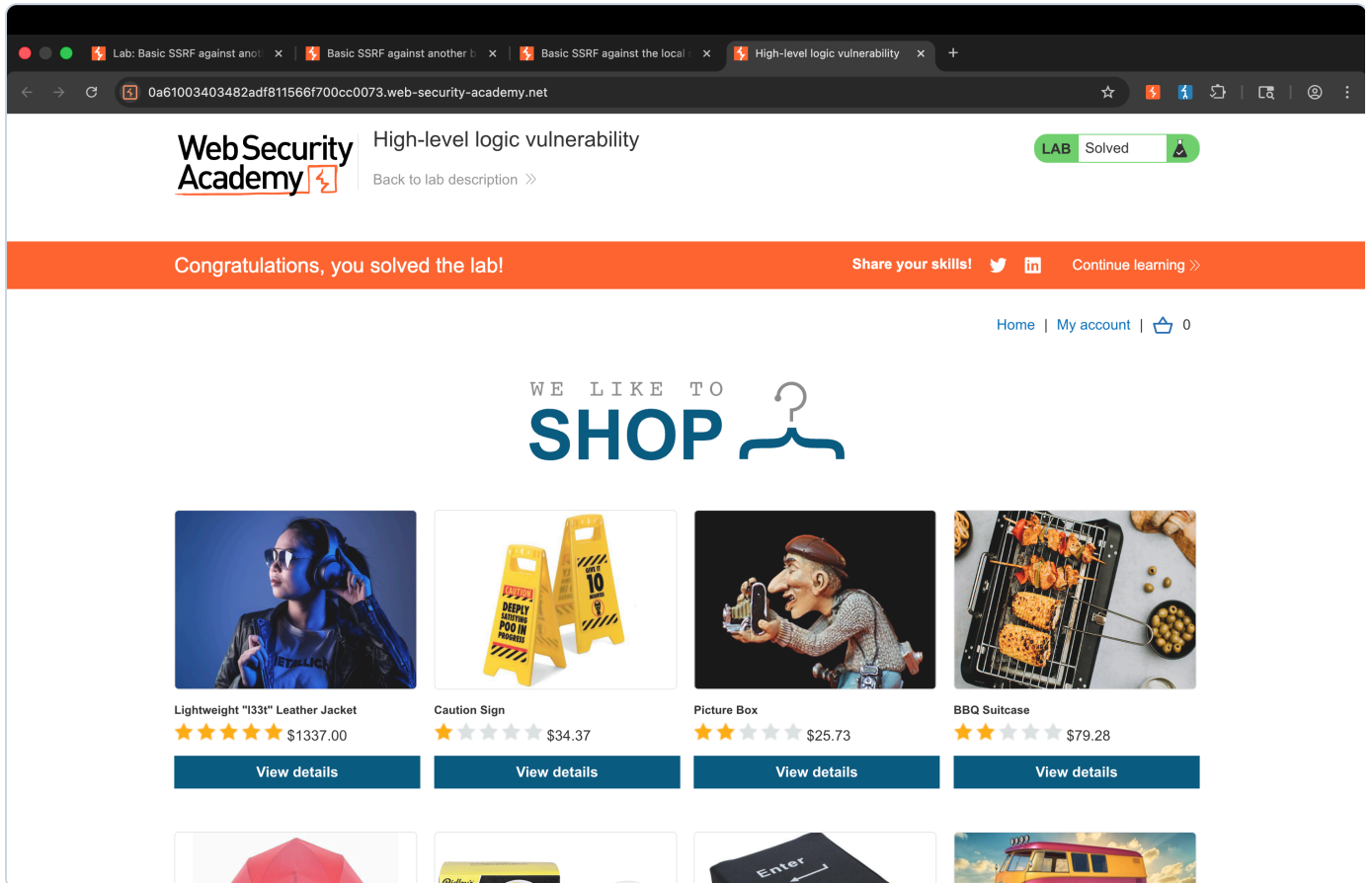
- Attack Vector: Network.
- Attack Complexity: Low.
- Privileges Required: Low - requires an authenticated session.
- User Interaction: None.
- Integrity: High - financial integrity of orders compromised.
- Confidentiality / Availability: None.

BizLogic Negative Quantity

Proof of Concept — Exploitation Evidence

Payload / exploit steps are documented in the **Proof of Concept** section of this writeup (above). Screenshot evidence of successful exploitation is shown below.

Lab Solved Confirmation



PortSwigger lab status changed to "Solved" after exploitation.